

The Risk Domain That **Doesn't Exist** (Yet)

Rob Knowles, M.S., CISSP, GCITP

Principal Insider Threat Analyst, Navy Federal Credit Union

Chair, FS-ISAC Insider Threat Working Group Steering Committee

insiderthreatanalyst.com

\$20.68M

average annual insider threat cost per financial services organization

Second-highest of any sector. 3.8 incidents per month on average. Costs up 123% since 2018.

55% of these incidents are caused by negligent employees — not malicious actors. Your crisis plan probably assumes a bad actor. Most of your real incidents are good people making mistakes.

The 8 / 80 Rule

8% of employees are responsible for 80% of security incidents. This isn't a technology problem — it's a human behavior problem. And it cuts across every risk domain you already manage.

So here's the question: does human risk deserve its own domain in your enterprise risk taxonomy — alongside operational risk, credit risk, market risk? Or is it a cross-cutting factor that lives inside every other domain?

Join the poll · menti.com · **9454 6868**

Two Ways to See It

FOR A DEDICATED DOMAIN

Dedicated ownership. Dedicated budget. Dedicated metrics. Without a home, human risk is everyone's problem and nobody's program. You can't improve what you don't measure, and you can't measure what doesn't have a name.

AGAINST A DEDICATED DOMAIN

Siloing creates the illusion that it's contained. Human risk *is* operational risk, *is* compliance risk, *is* third-party risk. A dedicated domain might let other risk owners abdicate: "that's the human risk team's problem."

I've argued both sides. I don't think there's a clean answer — and I'd genuinely like to hear how this group thinks about it. But hold that thought, because the picture just got more complicated.

The Insider That Doesn't Attend Your Security Awareness Training

The traditional insider threat picture assumed a human with credentials, access, and either intent or negligence. As of 2026, the fastest-growing population of "insiders" in your organization isn't human. They don't have a badge. They don't take PTO. And your insider threat program almost certainly isn't watching them.

Shadow AI: Three Waves

1 **Data leakage** (2023–2024)

Employees paste sensitive data into ChatGPT. A familiar DLP problem in a new wrapper. Security teams responded with the controls they already had.

2 **Autonomous agents** (2025–now)

Employees deploy AI agents with API access that chain actions across services at machine speed. Agents inherit permissions, operate continuously, and make decisions without human review. 47% of enterprise AI use happens through personal accounts outside SSO.

3 **Adversarial exploitation** (emerging)

Threat actors exploit agent infrastructure to move laterally. The same autonomous capabilities that make agents productive make them high-value targets. 79% of organizations lack visibility into AI agents in their environment.

THE GOVERNANCE GAP

19%

of organizations classify AI agents as equivalent to human insiders

Join the poll · menti.com · **9454 6868**

Your BCP and incident response plans account for a rogue employee or a compromised credential.

Consider whether they also account for an autonomous agent that inherited a senior analyst's permissions — operating at machine speed, 24/7, across every system it can reach, with no break and no second approval.

The blast radius math changes when the "insider" doesn't sleep and doesn't hesitate.

Three Things to Consider This Quarter

1 · INVENTORY

Identify where AI agents are operating in your environment — sanctioned and unsanctioned. Consider tools like Microsoft's Security Copilot, which now discovers 18 agent types on endpoints. You can't govern what you can't see.

2 · ASSIGN AN OWNER

Decide who owns autonomous-agent risk before an incident does — insider risk, incident response, or identity management. The home varies by org; what can't vary is that agents with credentials, access, and autonomy get a named owner and a behavioral baseline, instead of falling through the gap between teams.

3 · EXERCISE

Consider adding an "autonomous agent incident" scenario to your next tabletop. What does your IRP look like when the insider is software you deployed on purpose?

DISCUSSION

We built insider threat programs around the assumption that insiders are **people**. The fastest-growing population of insiders in your organization right now **isn't**.

What does your resilience plan look like when the threat is something you deployed on purpose?

Rob Knowles · insiderthreatanalyst.com
Slides available at insiderthreatanalyst.com/fsisacbrc

References

Ponemon Institute / DTEX. Cost of Insider Risks 2026. Annual benchmark study. \$19.5M global average, \$20.68M financial services.

Mimecast. The State of Human Risk 2026. Survey of 2,500 IT security decision makers across 9 countries. 8% / 80% finding, shadow AI governance gap data.

DTEX. 2026 Insider Threat Report. 92% of organizations say GenAI has changed information access patterns. 19% classify AI agents as equivalent to human insiders.

Cloud Security Alliance (CSA). "Shadow AI Agents: The Insider Threat You're Not Monitoring Yet." May 26, 2026. 47% personal account usage, 79% agent visibility gap.

CrowdStrike. 2026 Global Threat Report. AI tool exploitation at 90+ organizations, 550% increase in ChatGPT references in criminal forums.

Flashpoint. Insider Threats: Turning 2025 Intelligence into a 2026 Defense Strategy. 91,321 instances of insider recruiting observed in 2025.

Verizon. 2025 Data Breach Investigations Report (DBIR). 30% of breaches attributed to insiders.

SIFMA. Insider Threat Best Practices Guide, 3rd Edition (July 2024). Financial sector-specific guidance, North Korean IT worker case studies.

FTI Consulting. "Rethinking Threat Management in Financial Institutions." Whole-of-Person behavioral threat assessment model. TD Bank \$1.8B BSA/AML resolution case.

FS-ISAC AI Risk Working Group. Charting the Course of AI: Practical Considerations for Financial Services Leaders (2025). All-hazards framework for AI adoption; addresses shadow AI, the insider-by-mistake risk, and the medium-term shift to agentic AI. Available on the FS-ISAC member portal.